



ISO 27001 / NIS2 / BSI BASIC PROTECTION

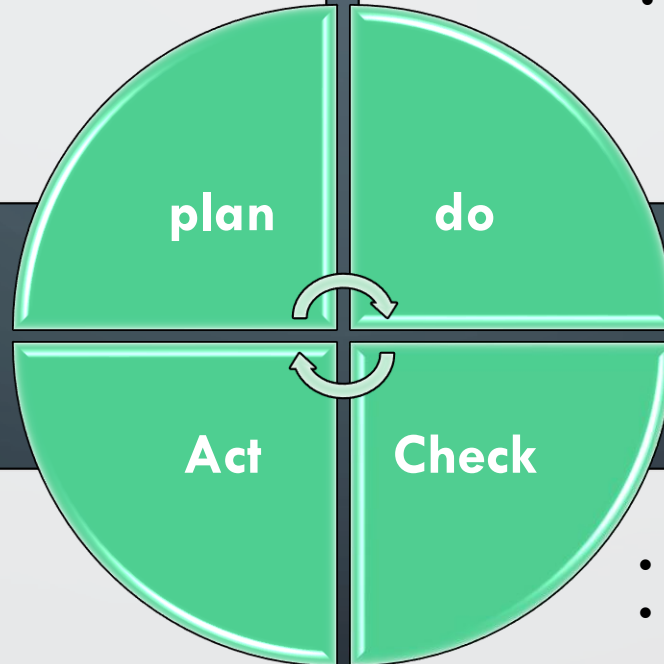
OVERVIEW: ISO 27001 / NIS2 / BSI BASIC PROTECTION

- The following is an overview of
 - ISO 27001 & 27002
 - NIS2 Directive
 - BSI Basic Protection
- The major similarities and differences are highlighted.

COMMONALITY: PDCA

- Goal and requirements definition
- Conduct a risk analysis
- Plan risk-minimizing controls

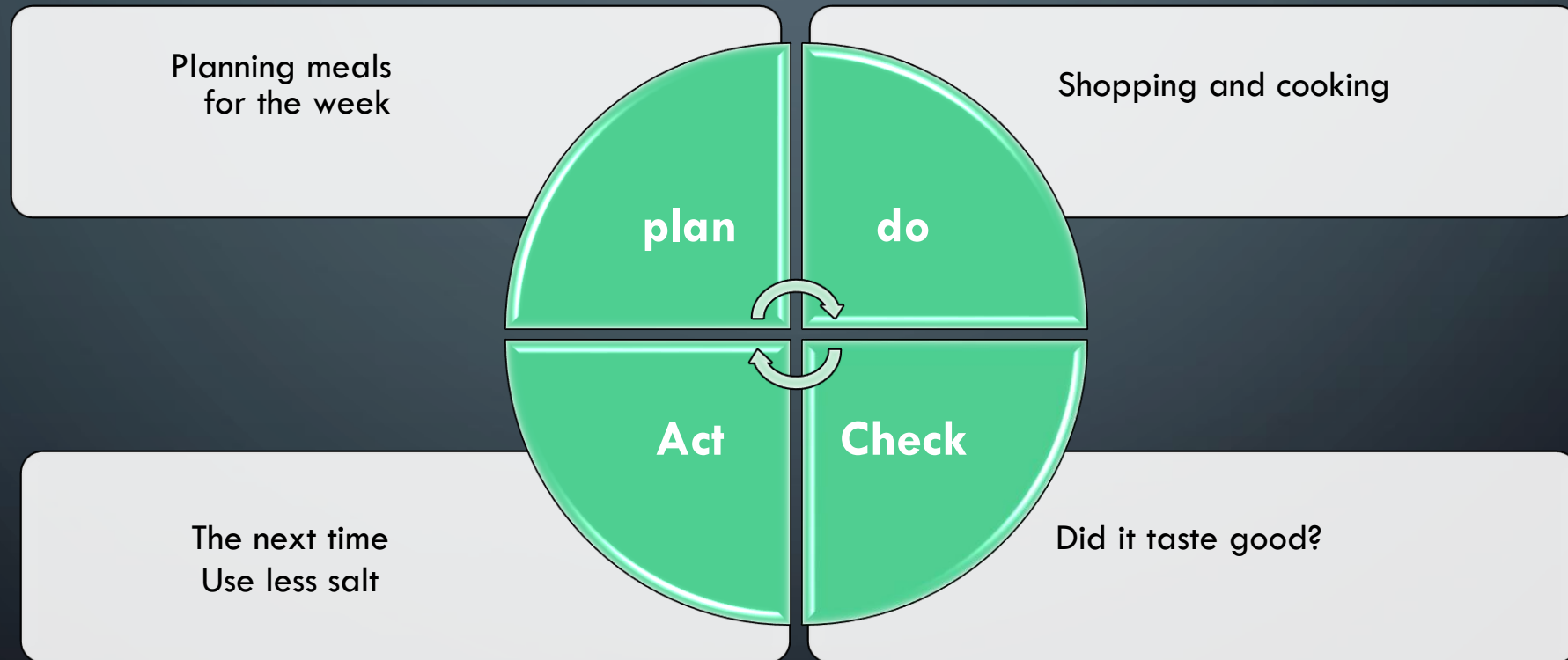
- Implementation of the plan



- Results analysis
- Define corrections
- Make process adjustments

- Monitoring & Measuring Results
- Internal audits

COMMONALITY: PDCA - EXAMPLE



COMMONALITY: PDCA

- PDCA cycle, also called Continuous Improvement Cycle or Deming Cycle
- Deming popularized this approach in the 1950s. He used it to improve quality and processes.
- This approach originally dates back to Shewart (1920s).

COMMONALITY: PDCA

- Divide yourselves into 3 groups and fill in the table – 1 example per group:

Example	plan	do	Check	Act
1. Implementation of a new password management system				
2. Safety awareness training for employees				
3. Introduction of a new backup strategy				

DEMING CYCLE IN ACTION

Example	plan	do	Check	Act
1. Implementation of a new password management system	Analysis of current password security guidelines and identification of vulnerabilities.	Implementation of a password management system and training of employees.	Review of password usage and conducting a password security audit.	Adjusting password complexity guidelines based on the audit results.
2. Safety awareness training for employees	Planning a training program to raise employee awareness of information security.	Conducting training and awareness campaigns for all employees.	Evaluation of training participation and implementation of a test to assess the effectiveness of the training.	Adaptation of the training program based on feedback and test results.
3. Introduction of a new backup strategy	Definition of backup goals, analysis of current backup methods, and planning of new strategies.	Implementation of the new backup strategy, including automated backups.	Verification of backup integrity through regular restore tests.	Improvement of the backup frequency or storage capacity based on the test results.

COMMONALITY: PDCA

- All three standards/laws are based on the PDCA cycle and are more or less clearly recognizable within them.
- As far as ISO standards are concerned, the PDCA cycle is integrated into the so-called High Level Structure.
- The standards 9001 (quality), 14001 (environment) and 27001 (information security) have already been converted to HLS.

COMMONALITY: PDCA

- The subchapters of the main chapters differ in the individual ISO standards.

WHERE CAN THE STANDARDS BE FOUND?

- The ISO standards can be found here:

<https://www.nautos.de/POG/search/item-detail/DE30099050>

Access is only possible via VPN.

ISO 27001: PDCA

Phase	Mapping to the HLS of the ISO standard
Plan	• Chapter 4: Context of the Organization – Understanding the internal and external influences and requirements. • Chapter 5: Leadership – Setting goals, responsibilities and the security strategy. • Chapter 6: Planning – Risk analysis and planning of controls to achieve the objectives.
Do	• Chapter 7: Support – Providing the resources, training, and skills for implementation. • Chapter 8: Operation – Implementation of the planned controls and security controls.
Check	• Chapter 9: Performance Evaluation – Monitoring, measuring and evaluating the performance and effectiveness of safety controls through audits and reviews.
Act	• Chapter 10: Improvement – Derivation of corrective controls and continuous improvement of the system based on the insights gained.

ISO 27001: PDCA

Chapter	Explanation
1. Scope of application	Defines what the standard covers and to which area or processes the management system is to be applied.
2. Normative references	Contains references to other standards or documents that are necessary for understanding or applying the respective ISO standard.
3. Terms	Defines the essential terms and definitions used in the standard to avoid misunderstandings.
4. Context of the organization	Analyzes the internal and external factors that influence the organization and identifies the expectations of relevant interested parties.
5. Leadership	Establishes the responsibility of top management to define objectives and ensure commitment to the management system.
6. Planning	Describes the risk assessment, risk treatment, and action planning to achieve the defined goals and to manage risks.
7. Support	Focuses on providing resources, training, communication and documentation to ensure the effectiveness of the management system.
8. Operation	Explains how the planned controls will be implemented, including the management and execution of operational processes.
9. Performance Evaluation	Ensure that the organization monitors and controls its processes and verifies their effectiveness through internal audits and management reviews.
10. Improvement	Addresses the continuous improvement of the system, including the implementation of corrective actions in case of nonconformities.

The background is a dark blue gradient. In the corners, there are white, stylized circuit-like lines with small circles at the ends, resembling a network or data flow diagram.

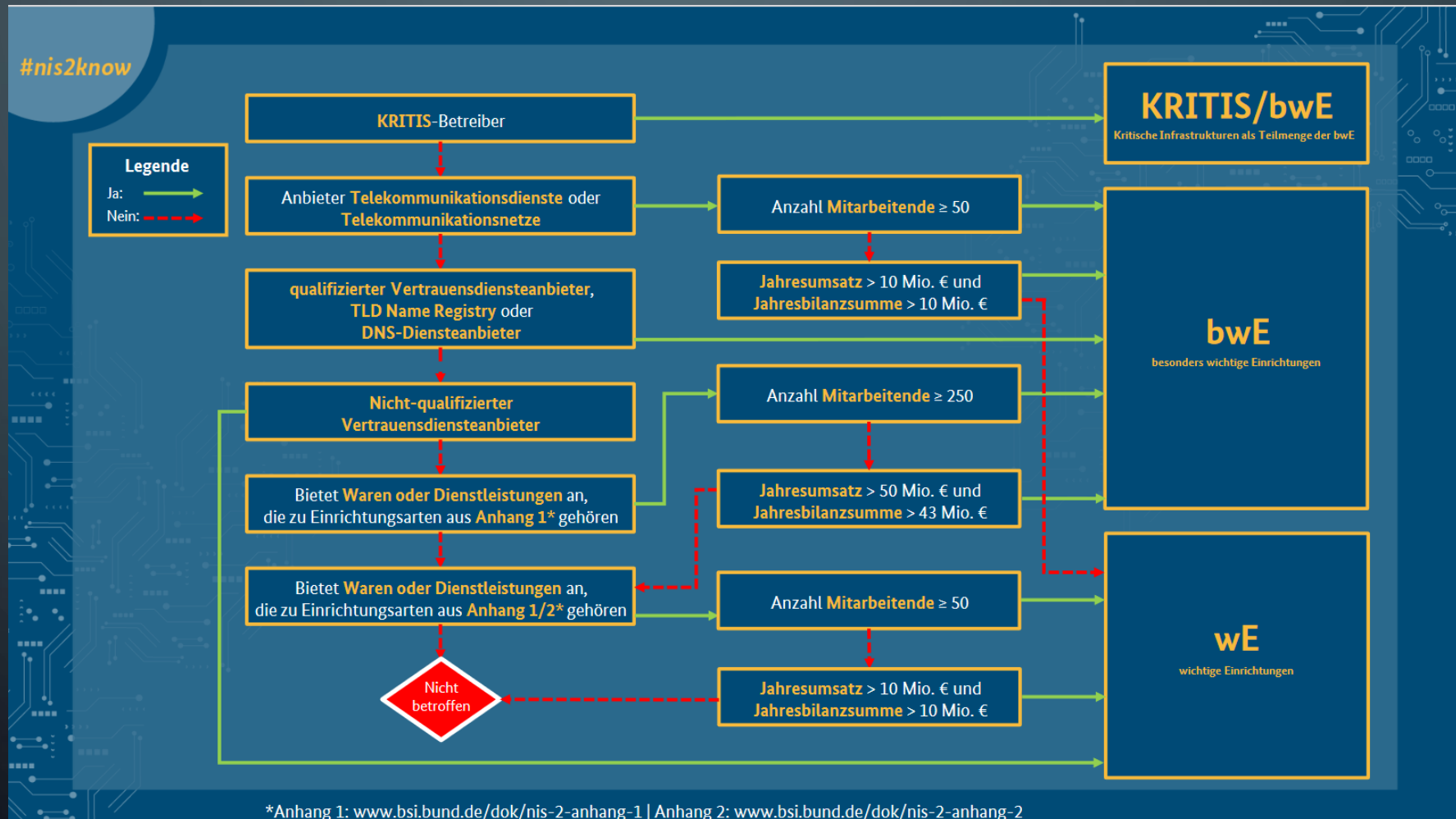
LEGAL REQUIREMENTS

IS THE STANDARD MANDATORY?

Standard/norm	Legal obligation?	Voluntary introduction - Why?
NIS2 (Network and Information Security Directive 2)	Yes , for all affected companies (see next slide)	Improving IT security in companies.
		Avoidance of heavy penalties for non-compliance.
		Strengthening resilience against cyberattacks.
ISO 27001	No , there is no legal obligation to implement ISO 27001.	Strengthening the trust of customers and partners.
		Compliance with industry-specific requirements (e.g. GDPR, NIS2).
		Competitiveness.
BSI IT Baseline Protection	No , there is no direct legal obligation to implement the BSI basic protection.	Based on German standards and preferred by many public institutions.
		A holistic approach to IT security with concrete controls and requirements.
		Support from the BSI.

NIS2: ARE COMPANIES AFFECTED?

source



NIS2: ARE COMPANIES AFFECTED?

- Go to: <https://www.openkritis.de>



Click here 

KRITIS und NIS2

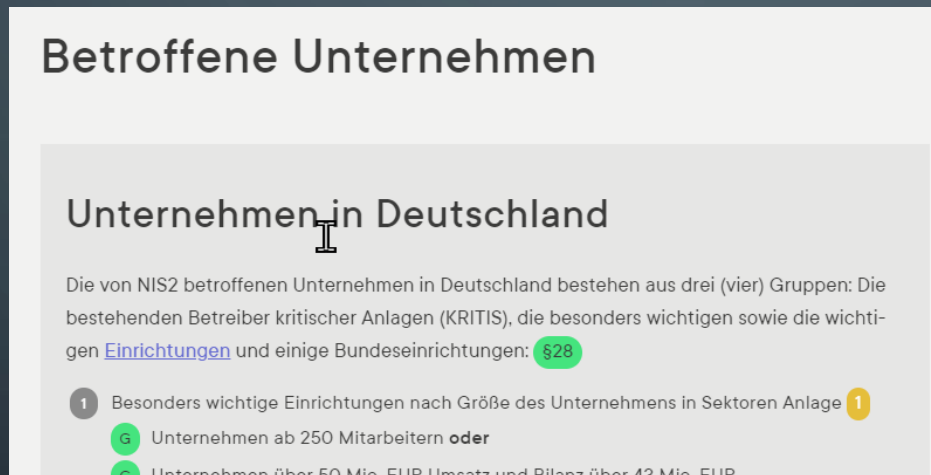
- Die NIS2-Umsetzung in Deutschland
- Neues KRITIS-Datenschutzgesetz für Resilienz
- Europa: Richtlinien EU NIS2 und EU RCE
- OpenKRITIS-School zu KRITIS und NIS2
- OpenKRITIS RSS-Feed, LinkedIn, News

You will land on:

<https://www.openkritis.de/it-sicherheitsgesetz/nis2-umsetzung-gesetz-cybersicherheit.html>

NIS2: ARE COMPANIES AFFECTED?

- Take a look at the "Affected Companies" section.



The screenshot shows a webpage titled "Betroffene Unternehmen" (Affected Companies). Below the title is a section "Unternehmen in Deutschland" (Companies in Germany). The text explains that companies affected by NIS2 in Germany consist of three (four) groups: operators of critical infrastructure (KRITIS), particularly important and important facilities, and some federal institutions. A green circle highlights "§28". Below this, a numbered list starts with "1. Besonders wichtige Einrichtungen nach Größe des Unternehmens in Sektoren Anlage" (1. Particularly important facilities according to the size of the company in sectors of infrastructure). Two green circles highlight "Unternehmen ab 250 Mitarbeitern" (Companies with 250 or more employees) and "oder" (or). A second green circle highlights "Unternehmen über 50 Mio. EUR Umsatz und Bilanz über 43 Mio. EUR" (Companies with over 50 million EUR turnover and balance sheet over 43 million EUR).

Betroffene Unternehmen

Unternehmen in Deutschland

Die von NIS2 betroffenen Unternehmen in Deutschland bestehen aus drei (vier) Gruppen: Die bestehenden Betreiber kritischer Anlagen (KRITIS), die besonders wichtigen sowie die wichtigen [Einrichtungen](#) und einige Bundeseinrichtungen: §28

1. Besonders wichtige Einrichtungen nach Größe des Unternehmens in Sektoren Anlage 1

- Unternehmen ab 250 Mitarbeitern oder
- Unternehmen über 50 Mio. EUR Umsatz und Bilanz über 43 Mio. EUR

- Is it now clearer which companies are affected?
(Here's another impact assessment tool from the BSI (<https://betroffenheitspruefung-nis-2.bsi.de/>)

NIS2: ARE COMPANIES AFFECTED? (STATUS: 10/2024)

1. Imagine yourself in the position of a company that might be affected by NIS 2.
2. Check out the FAQs [here](#) (Official BSI website)

Sollten wir als betroffenes Unternehmen auf das Inkrafttreten des
BSIG-E/Umsetzung NIS-2 warten, oder wie sollten wir uns
vorbereiten?

Unternehmen sollten sich vor allem auf die NIS-2-Regulierung vorbereiten, indem sie ihre Informationssicherheit verbessern und konkrete technisch-organisatorische Maßnahmen umsetzen. Unbenommen der zu erwartenden gesetzlichen Regulierung durch die Änderungen des BSI-Gesetzes aufgrund der Umsetzung der NIS-2-Richtlinie empfiehlt das BSI auf Grund der IT-Sicherheitslage jederzeit und für jedes Unternehmen, das eigene IT-Sicherheitsniveau kontinuierlich zu verbessern und zu erhöhen.

Status:
October 17, 2024

3. What must/can they do as a potentially affected company?

NIS2: ARE COMPANIES AFFECTED? (STATUS: 10/2025)

1. Imagine yourself in the position of a company that might be affected by NIS 2.
2. Check out the FAQs [here](#) (Official BSI website)



2. Sollten wir als betroffenes Unternehmen auf das Inkrafttreten eines Gesetzes zur Umsetzung der NIS-2-Richtlinie warten warten, oder wie sollten wir uns vorbereiten?

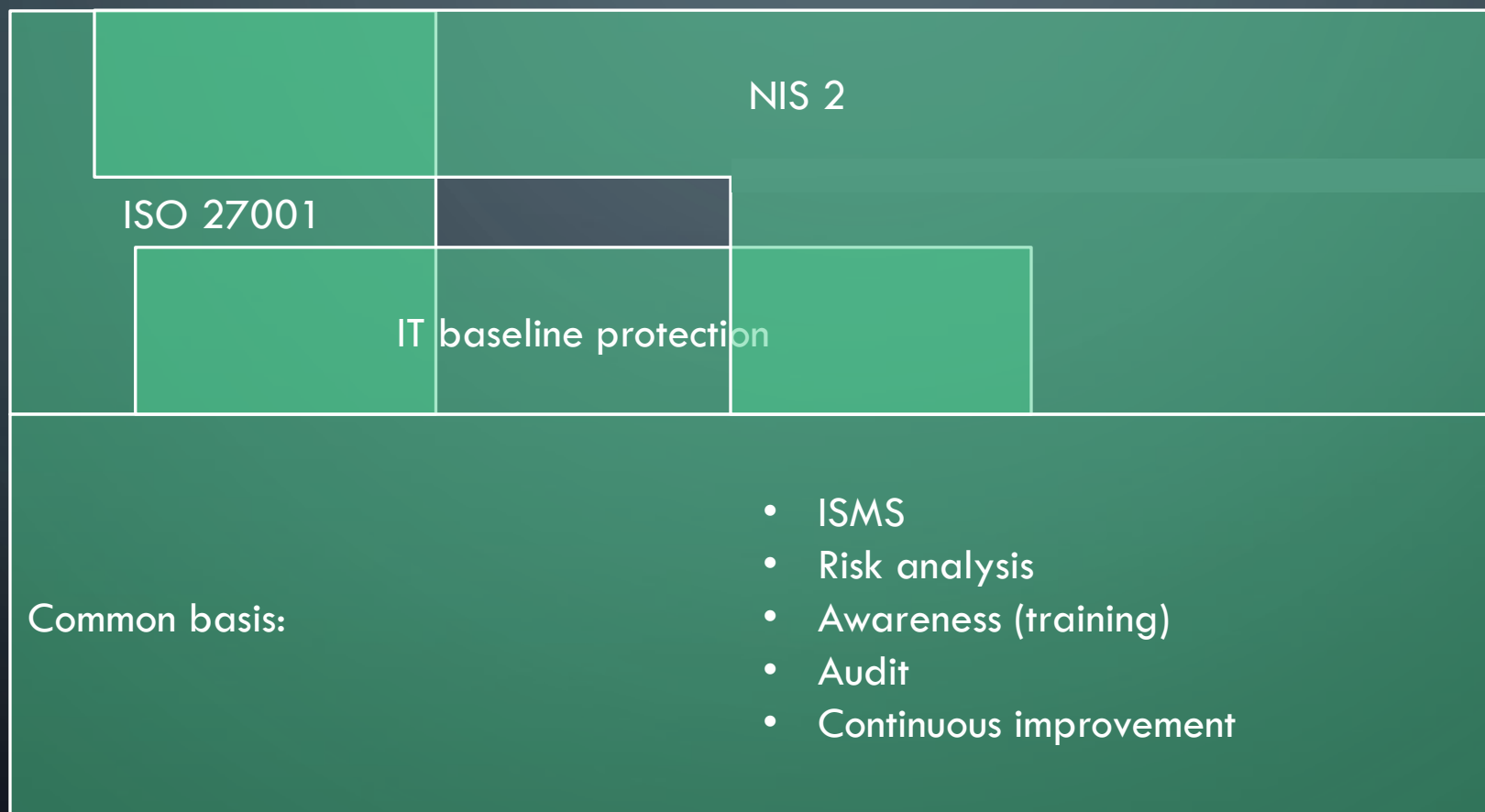
Unternehmen sollten sich vor allem auf die NIS-2-Regulierung vorbereiten, indem sie ihre Informationssicherheit verbessern und konkrete technisch-organisatorische Maßnahmen umsetzen. Unbenommen der zu erwartenden gesetzlichen Regulierung durch die Änderungen des BSI-Gesetzes aufgrund der Umsetzung der NIS-2-Richtlinie empfiehlt das BSI auf Grund der IT-Sicherheitslage jederzeit und für jedes Unternehmen das eigene IT-Sicherheitsniveau kontinuierlich zu verbessern und zu erhöhen.

3. What must/can they do as a potentially affected company?

27001 OVERLAP WITH NIS2 AND BSI BASIC PROTECTION

Standard/Requirement	Percentage fulfillment through ISO 27001 certification (estimated)	Details
BSI IT Baseline Protection	50-60%	ISO 27001 covers essential aspects of IT security such as risk management, ISMS, and security policies. However, the BSI IT Baseline Protection goes further in depth and offers a comprehensive catalog of specific controls that are more detailed and stringent than those of ISO 27001. This applies in particular to the layered approach and the catalogs of security requirements.
NIS2 Directive	70-80%	ISO 27001 fulfills many requirements for ISMS, risk management, and control controls. However, NIS2 requires additional specific obligations such as extended reporting requirements, cooperation with national authorities, and controls to ensure availability that go beyond ISO 27001.

27001 OVERLAP WITH NIS2 AND BSI BASIC PROTECTION



ISO 27001: AREAS THAT EXCEED NIS2 AND BSI BASIC PROTECTION I

Requirement	ISO 27001	NIS2	BSI IT Baseline Protection	Where ISO 27001 continues
International focus	Global, internationally recognized standard	Limited to EU companies in critical infrastructure sectors	Specifically for Germany	ISO 27001 is a globally recognized standard that is used internationally and is not limited to the EU or Germany.
Management responsibility	Strong emphasis on the leadership and commitment of top management.	Requirements for leadership exist	Strong focus on technical aspects; management responsibility is present, but less emphasized.	ISO 27001 requires a stronger commitment from management and active participation in the security strategy.
Flexibility in implementation	Very flexible, adapted to company size and risk	Stricter regulations for critical infrastructure companies	Methodical, based on standardized controls	ISO 27001 offers more flexibility and is scalable for companies of any size and industry, while BSI and NIS2 have more specific requirements.
Risk management process	Integrated, comprehensive risk management system (ISMS)	Risk management is required, but less specific.	Methodical approach, but with a more detailed focus on technical controls	ISO 27001 relies on comprehensive, continuous risk management that delves deeper into organizational risks than NIS2 or BSI Basic Protection.
Application range	Can be used for any type of information (not just IT).	Focused on IT systems and networks	Focused on IT systems, networks and technical controls	ISO 27001 refers to the security of all types of information, not just IT systems, and therefore has a broader scope.

ISO 27001: AREAS THAT EXCEED NIS2 AND BSI BASELINE PROTECTION II

Requirement	ISO 27001	NIS2	BSI IT Baseline Protection	Where ISO 27001 continues
Continuous improvement	He strongly emphasizes the cycle of continuous improvement (PDCA).	Improvement mechanisms exist	Includes continuous improvement	ISO 27001 relies on a continuous improvement process (PDCA), while NIS2 and BSI focus more on compliance and specific controls.
Focus on non-IT risks	This also refers to non-technical risks, e.g., social, organizational, and physical risks.	Focuses primarily on IT and network security	Technical focus, especially on IT systems and networks	ISO 27001 offers a more comprehensive approach that also includes non-technical risks, such as organizational and human factors.
Training and awareness-raising	Requires comprehensive training and awareness programs for all employees	Training is mandatory, but less detailed.	It mentions training courses, but no detailed specifications.	ISO 27001 emphasizes the need for a training and awareness program for all employees, not just IT staff.
Contract management with suppliers	He strongly emphasizes the security requirements in contracts with suppliers.	Security requirements for suppliers exist	Security requirements for suppliers, but less detailed	ISO 27001 ensures that supplier contracts contain clearly defined security requirements, which is more detailed than NIS2 or BSI Basic Protection.
Certification	Certification audit required every 3 years	No certification yet – but critical infrastructure companies must provide proof (TÜV, every 2 years). ISO 27001 alone is not sufficient. Important and very important companies are exempt from this requirement.	It can be checked, but it doesn't have to be. No certificate.	ISO 27001 is only considered fully implemented with certification. The external impact is correspondingly high.

ISO 27002

- It consists of 93 controls (security controls), divided into 4 areas:
 1. Organizational controls
 2. Personal controls
 3. Physical controls
 4. Technological controls

4 AREAS OF ISO 27002

Area	Explanation
1. Organizational controls	controls relating to guidelines, processes, and procedures necessary for managing information security. These are not technology-dependent.
2. Technical controls	controls that utilize technology to ensure information security. These controls primarily concern IT infrastructure, systems, and networks.
3. Physical controls	controls aimed at protecting physical locations, equipment and infrastructure, e.g. access controls and security precautions for buildings.
4. Personal controls	controls concerning employee behavior and training. They aim to ensure that staff act in a safety-conscious manner and are properly trained.

RELATIONSHIP: 27001 APPENDIX A & 27002

aspect	ISO 27001 Annex A	ISO 27002
Purpose	List of safety controls for risk treatment	Guidelines for the implementation of these controls
Detailing	Generally speaking	Detailed instructions and best practices
use	Reference for creating the SoA	Support for practical implementation in the company

RELATIONSHIP: 27001 APPENDIX A & 27002

Area of Annex A	Control (ISO 27001 Annex A)	Implementation (ISO 27002)
1. Organizational controls	A.5.1 Information Security Policy and Guidelines	ISO 27002 (p. 20) recommends that the information security policy describe the goals and principles of information security within the organization. This policy should be approved by top management and reviewed regularly to ensure it remains relevant to current threats and business objectives. It should clearly define who is responsible for its implementation (and the consequences of violations).
2. Technological controls	A.8.2 Management of privileged access rights	According to ISO 27002 (p. 113), privileged access rights should only be granted after a strict approval process. It is recommended to define specific user roles tailored to particular tasks and responsibilities. Regular reviews of these rights are necessary to ensure that access rights correspond to the users' current tasks and authority. The use of administrator accounts should be minimized (and multi-factor authentication is recommended).
3. Physical controls	A.7.5 Protection against physical and environmental threats	ISO 27002 (p. 98) emphasizes the importance of taking security precautions against physical threats such as fire, water, earthquakes, or theft. It recommends securing critical areas with alarm systems, fire protection systems, and access restrictions. (Regular testing and maintenance of the security systems are necessary to ensure they function properly in an emergency.)
4. Personal controls	A.6.3 Information security awareness, education and training	ISO 27002 (p. 85) states that all employees should receive regular information security training to identify potential risks and respond appropriately. The training should be tailored to the specific roles and responsibilities of each employee. It is also recommended to promote security awareness through regular campaigns and awareness initiatives. (New employees should be briefed on security procedures before being granted access to company resources.)

The background is a dark blue gradient. In the corners, there are white, stylized circuit-like lines with small circles at the ends, resembling a network or data flow diagram.

INFORMATION SECURITY MANAGEMENT SYSTEM (ISMS)

QUESTIONS (RELATED TO ISO 27001):

1. What is an ISMS? What isn't it? What does it include? What doesn't it include?
2. Who is affected by the ISMS in the context of a company? Who is not affected by it?
3. How long does it take to set up an ISMS? What are the costs? In which cases can the costs be justified?

ANSWER

Ask	Answer / Explanation
1. What is an ISMS? What is it not? What does it include? What does it not include?	An ISMS (<i>Information Security Management System</i>) is a systematic approach to planning, implementing, monitoring, and continuously improving information security. It includes processes, policies, responsibilities, training, and technical controls . ❌ Individual tools, firewalls, or IT departments alone do not constitute an ISMS . ✅ An ISMS is the organizational structure that ensures technical, organizational, and human controls work together seamlessly.
2. Who is affected by the ISMS in the context of a company? Who is not affected by it?	An Information Security Management System (ISMS) affects all individuals and departments that handle information – including management, IT, HR, purchasing, sales, production, etc. Information security is not just an IT responsibility , but a company responsibility. Only external actors without access to information are not directly affected, but suppliers and service providers must be integrated into the system.
3. How long does it take to set up an ISMS? What are the costs? In which cases can the costs be justified?	Duration: 6–12 months for SMEs, depending on size and initial situation. Costs: approx. €10,000–30,000 (including consulting, documentation, training, and certification). Justification: • Compliance with legal requirements (e.g., NIS2, KRITIS). • Reduction of security incidents, fines, and downtime. • Demonstrable trustworthiness with customers and partners. • Lower long-term damage costs and improved market position.

ISMS

- The goal of ISO 27001 is to establish and maintain information security.
- The entirety of organizational, process-based and technical requirements to achieve this is called ISMS (Information Security Management System).
- ISO 27001 is the globally recognized standard for setting up, operating and improving an ISMS tailored to the individual needs of the company.

COST

Source:

[https://www.secjur.com/blog/iso-27001#ISO27001 in comparison with other information security standards](https://www.secjur.com/blog/iso-27001#ISO27001%20in%20comparison%20with%20other%20information%20security%20standards)

(Please enjoy with caution.)
This company offers a software-products for ISO 27001 management.)

Was kostet die ISO 27001 Zertifizierung?

Die Kosten für eine ISO 27001 Zertifizierung können erheblich variieren, abhängig von der Größe und Komplexität der Organisation, dem Standort, der Anzahl der zu zertifizierenden Geschäftseinheiten und den Gebühren der Zertifizierungsstelle. Generell lassen sich die Kosten in drei Hauptbereiche gliedern: Kosten für den Auditor/die Zertifizierungsstelle, interne Aufwände und Kosten für externe Expertise.

- 1. Kosten für Auditor/Zertifizierungsstelle:** Die Auditkosten umfassen die Gebühren der Zertifizierungsstelle für die Durchführung des Zertifizierungsaudits sowie der jährlichen Überwachungsaudits und der Rezertifizierung nach drei Jahren. Die Höhe dieser Gebühren variiert je nach Anbieter und Region. Für ein Unternehmen mit 50 Mitarbeitenden und mittlerer Komplexität kann **grob von 10.000 Euro pro Jahr** ausgegangen werden. Während die Kosten für das initiale Audit in der Regel am höchsten sind, fallen für die Überwachungsaudits und die Rezertifizierung ebenfalls nicht zu unterschätzende Kosten an.
- 2. Interne Aufwände:** Die internen Aufwände umfassen die Zeit und Ressourcen, die Ihre Organisation direkt in die Vorbereitung und Aufrechterhaltung des Informationssicherheitsmanagementsystems (ISMS) investiert. Dazu gehören die Zeit für die Schulung von Mitarbeitern, die Durchführung interner Audits, die Risikobewertung und -behandlung sowie die Implementierung von Sicherheitskontrollen. Diese Kosten können schwer zu quantifizieren sein, da sie stark von der bestehenden Ausgangslage und den internen Kapazitäten abhängen. Eine wesentliche Rolle spielen dabei die Mitarbeiterstunden, die für Planung, Implementierung und Management des ISMS aufgewendet werden. Erneut von 50 Mitarbeitenden in einer Organisation mittlerer Komplexität ausgehend, lässt sich sehr grob sagen, dass **ein halber bis zwei Personentage an Aufwänden pro Woche** entstehen.
- 3. Kosten für externe Expertise:** Viele Organisationen ziehen es vor, externe Berater oder Sicherheitsexperten hinzuzuziehen, um bei der Vorbereitung auf die ISO 27001 Zertifizierung zu unterstützen. Diese Experten können wertvolle Unterstützung bei der Erstellung der erforderlichen Dokumentation, der Implementierung von Sicherheitskontrollen und der Schulung von Mitarbeitern leisten. Die Kosten für externe Beratung variieren ebenfalls stark, je nach Bedarf und Dauer des Projekts, und können **von einigen Zehntausenden bis hin zu Hunderttausenden Euro reichen**.

WHAT IS TO BE ACHIEVED: CIA

Expression	Explanation	Examples
Confidentiality	Protecting information from unauthorized access to ensure privacy and security requirements.	1. Access control : Only authorized employees can access customer data.
		2. Data encryption : Sensitive information is encrypted to prevent unauthorized reading.
Integrity	Ensuring that information is complete and unaltered, and that only authorized changes are made.	1. Version control : Documents are versioned to track changes.
		2. Checksums : Data integrity is verified through check mechanisms such as hashes.
Availability	Ensuring that information and systems are accessible and functional when needed.	1. Redundant systems : Critical servers are mirrored to minimize downtime.
		2. Backup procedures : Regular backups enable recovery after a system failure.

TASK: EVERYDAY ISMS

- Split into groups
- Choose a scenario
- Create the beginning of the PDCA cycle.

plan	What information is worth protecting?
do	How are they protected?
Check	How do you check if the protection is working?
Act	What do you do if something goes wrong?

Everyday ISMS (please select)
1. Household budget
2. Fitness or nutrition plan
3. Password Management
4. Family or shared apartment calendar
5. Data backup at home
6. Study or project organization

EXAMPLE ANSWERS

Everyday ISMS	plan	do	Check	Act
1. Household budget	Analyze income and expenses, set budget goals	Document and compare expenses	Check monthly whether the budget has been adhered to.	Adjust budget or spending categories
2. Fitness or nutrition plan	Set training and nutrition goals	Consistently implement the plan (training, meals)	Measure progress (e.g., weight, endurance)	Adjust training plan or diet
3. Password Management	Define password rules and protection requirements	Set up a password manager, activate MFA	Regularly check that passwords are secure and up-to-date.	Change passwords, add new accounts
4. Family or shared apartment calendar	Establish common rules for scheduling	Enter and coordinate dates	Check if any appointments conflict or have been forgotten.	Improve communication rules
5. Data backup at home	Specify which data should be backed up.	Perform regular backups	Test recovery	Adjust backup frequency or storage locations
6. Study or project organization	Planning learning objectives and deadlines	Complete tasks, achieve milestones	Check progress and grades	Optimize learning methods or time management

STARTING POINT TAKE OUT?

- The following two slides explain the circumstances that led TechSoft to decide to pursue ISO 27001 certification.
- Evaluate the information
- What information are you missing?

EXAMPLE COMPANY: TECHSOFT SOLUTIONS GMBH

critterion	Details
Industry	• IT services and software development with a focus on cloud-based solutions and digital transformation. • TechSoft Solutions offers tailored software solutions for small and medium-sized enterprises as well as customers from critical infrastructures (KRITIS), such as healthcare, energy supply and logistics.
Size and structure	• 150 employees, spread across a headquarters in Germany and several branches in other cities. • The IT department consists of 20 employees, including developers, network administrators and a dedicated IT security team.
Technical infrastructure	• TechSoft Solutions operates its own data center where it hosts cloud services for its customers. Among other things, highly critical data such as patient records in the healthcare sector and energy data are stored and processed here. • Cloud infrastructure comprises a mix of private and public cloud systems that must be protected by complex security mechanisms. • They also have a software development department responsible for their internal and external applications, including ensuring the Software Development Life Cycle (SDLC).

EXAMPLE COMPANY: TECHSOFT SOLUTIONS GMBH

critterion	Details
Motivation for ISO 27001 certification	• Certification is needed to meet the growing security requirements of customers, especially those in the critical infrastructure sector. • Compliance reasons such as adherence to the GDPR, the NIS2 Directive and other regulatory requirements, particularly when processing health and energy data. • The company aims to strengthen its market confidence, particularly among safety-critical customers, by obtaining ISO 27001 certification.
Challenges and risks	• Cyberattacks on cloud infrastructure could endanger sensitive data and lead to serious reputational damage. • Data leaks or security incidents could have legal consequences and jeopardize contracts with critical customers. • The requirements of the NIS2 directive and the need to ensure the availability and integrity of systems increase the pressure on security controls.

The slide features a dark blue gradient background with a large, faint, light blue circle centered behind the text. In the four corners, there are white, stylized circuit-like lines with small circles at various points, resembling a network or data flow diagram.

PLAN PHASE

(CHAPTERS 4, 5 AND 6)

SUMMARY

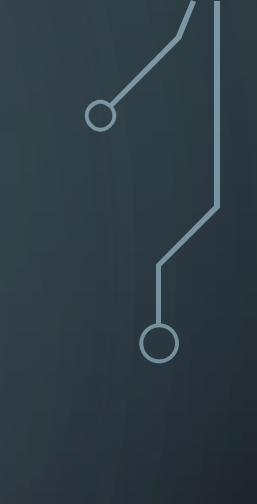
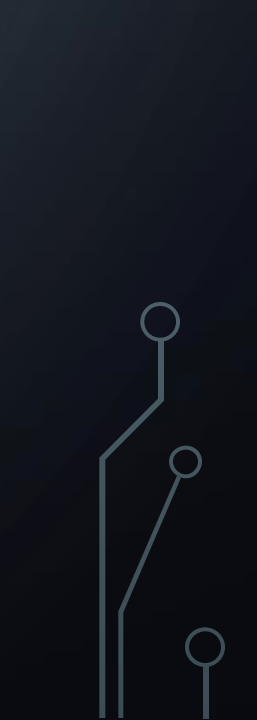
Chapter	title	Requirements
ISMS-4	context of the organization	Understanding the internal and external requirements (4.1) and the expectations of interested parties (4.2), defining the scope of the ISMS (4.3), and implementing and maintaining the ISMS (4.4)
ISMS-5	guide	Establish guidelines by top management (5.1), define security policy (5.2), and define roles, responsibilities and authorities for the ISMS in the organization (5.3)
ISMS-6	planning	Identify and plan for dealing with risks and opportunities (6.1), define security objectives and controls to achieve them (6.2), and plan and manage changes to the ISMS and processes (6.3)

CHAPTER 4: CONTEXT OF THE ORGANIZATION

Requirement	Who has to do it?	When will it be done?	Does it need to be documented?
4.1 Understanding the organization and its context	Management, ISMS Managers	At the start of ISMS implementation and during significant organizational changes	Yes, in the form of a written analysis of the internal and external context (e.g., report or section in ISMS documentation)
4.2 Understanding the needs and expectations of interested parties	Management, ISMS Managers	At the beginning and regularly (e.g. annually or when the interest groups change)	Yes, through a list of relevant stakeholders and their information security requirements (e.g., stakeholder analysis).
4.3 Defining the scope of the ISMS	Management, ISMS Managers	At the beginning and when the boundaries of the ISMS change	Yes, as a written scope (e.g., a section in the ISMS documentation that describes what the ISMS covers)
4.4 Establishment, implementation and maintenance of the ISMS	ISMS Managers, Management	Ongoing and in the event of changes to the ISMS	Yes, through complete ISMS documentation that includes all relevant processes and controls.



TASK:

- For each subchapter 4.1 to 4.4:
 - What questions are being addressed here?
 - What should you pay attention to / what should you place particular emphasis on when documenting?
- 
- 
- 

EXAMPLE ANSWERS

Section	Questions regarding the fulfillment of the section	documentation
4.1 Understanding the organization and its context	What are the internal and external factors that could affect our information security?	Documentation in the form of a context analysis or environmental analysis , which describes in writing the internal and external factors and their influence on information security. This can be filed as part of the ISMS manual or as a separate document.
	What legal, regulatory, and business requirements exist?	
	What trends or threats exist in our market?	
4.2 Understanding the needs and expectations of interested parties	Who are our relevant stakeholders (e.g., customers, employees, authorities)?	The expectations are documented in a stakeholder analysis , which includes a list of relevant interest groups and describes their specific requirements. This analysis can also be integrated into the ISMS manual or maintained as a separate document.
	What do these interest groups expect or demand regarding information security?	
	What legal or contractual requirements arise from these expectations?	
4.3 Defining the scope of the ISMS	Which departments, locations, information and IT systems does our ISMS encompass?	The scope of application is defined in an ISMS scope document , which clearly describes which parts of the organization, IT systems, data, and locations are included in the ISMS. Interfaces between these areas must also be clearly defined and documented to establish responsibilities and identify overlaps.
	What is outside the scope and why?	
	What specific requirements do the areas included in the scope of application have?	
4.4 Establishment, implementation and maintenance of the ISMS	What key processes and security controls do we need to achieve our information security goals?	The structure and processes of the ISMS are documented in an ISMS manual or ISMS process description , including responsibilities, resource planning, and methods for continuous improvement. All core processes and controls are clearly described here.
	How do we ensure that the ISMS is continuously improved?	
	What resources and responsibilities are needed?	

TASKS

Task 1: Context analysis of the example organization

Description : Define three internal and three external factors that could influence information security in our example organization. Consider internal structures, technologies, legal requirements, or industry-specific risks.

Question : Which internal and external factors must be considered in a context analysis for information security?

Task 2: Stakeholder expectations

Description : Identify two possible stakeholder groups of the example organization and describe one specific information security requirement of each group.

Question : What requirements might stakeholders have regarding information security, and why are these requirements important for the ISMS?

Task 3: Define the scope of the ISMS

Description : Describe which areas of the example organization should fall within the scope of the ISMS. Also, identify an interface between these areas that requires particularly clear definition.

Question : Which departments and locations should be included in the scope of the ISMS, and which interfaces between these areas require particular clarity?

Task 4: Implementation and maintenance of the ISMS

Description : List three key processes necessary for the implementation and maintenance of the ISMS. Briefly describe why these processes are important for a functioning ISMS.

Question : Which processes contribute to the successful implementation and continuous maintenance of the ISMS, and how do they promote information security?

EXAMPLE ANSWERS

Task	Example answer
1. Context analysis of the example organization	Internal factors :
	1. IT infrastructure and network security
	2. Employee competence in dealing with IT security
	3. Budget for information security controls
	External factors :
	1. Legal requirements (e.g. GDPR)
	2. Industry-wide security standards
	3. Technological developments (e.g., new security threats)

EXAMPLE ANSWERS

Task	Example answer
2. Stakeholder expectations	Stakeholder Group 1 : Customers
	Requirement : Ensuring the confidentiality and security of their data
	Why this is important : Customers expect their personal data to be protected and trust that the organization takes appropriate safeguards.
	Stakeholder Group 2 : Legislators
	Requirement : Compliance with all legal safety regulations
	Why it's important : The organization must meet legal requirements to avoid legal consequences and ensure compliance.

EXAMPLE ANSWERS

Task	Example answer
3. Define the scope of the ISMS	Departments and locations within the ISMS :
	1. IT Department (Administration of technical systems)
	2. Human Resources Department (Employee Data Management)
	3. Customer service (management of customer data)
	Interface : The interface between the IT and HR departments requires particular clarity, as the HR department manages IT access for new and departing employees.
4. Implementation and maintenance of the ISMS	Processes :
	1. Risk management process: Identifies and assesses security risks in order to plan and implement appropriate controls.
	2. Security Policy Management: Ensures that security policies are developed, communicated, and regularly reviewed.
	3. Monitoring and review process: Monitors the effectiveness of the ISMS and conducts regular audits to identify weaknesses and initiate improvements.

INFORMATION SECURITY POLICY

- The **information security policy** is a comprehensive document that establishes an organization's principles, objectives, and commitments regarding the protection of its information. It describes how the organization intends to ensure the confidentiality, integrity, and availability of information. The information security policy serves as a guideline for all employees and defines management's expectations for security behavior in order to minimize risks and meet legal and regulatory requirements.

INFORMATION SECURITY POLICY, EXAMPLES

1. Our organization is committed to protecting all confidential customer data through appropriate technical and organizational controls and granting access only to authorized personnel. Security incidents are investigated immediately and necessary corrective actions are implemented.
2. The goal of our information security policy is to ensure the availability, integrity, and confidentiality of our IT systems and data. All employees are required to comply with the established security guidelines and to report potential risks and vulnerabilities to the information security team.

CHAPTER 5: LEADERSHIP

Section	Who has to do it?	When will it be done?	Does it need to be documented?
5.1 Leadership and Commitment	Top management, ISMS managers	At the start of the ISMS implementation and regularly (e.g. annually) to review the commitment and in the event of significant changes in the company	Yes, through a management statement on information security , which documents management's commitment. This is often included in the ISMS manual or as a separate document.
5.2 Information Security Policy	Top management, ISMS managers	At the start of the ISMS, when introducing new security objectives and during major changes	Yes, through an information security policy that clearly defines how the company intends to achieve its security objectives. This policy is communicated to all employees and reviewed regularly.
5.3 Roles, responsibilities and authorities in the organization	ISMS managers, possibly management and HR	At the start of the ISMS and when there are changes in responsibilities or roles	Yes, through a role and responsibility matrix or job descriptions that clearly define who is responsible for which parts of the ISMS. This information can be recorded in the ISMS manual or in separate documentation.

TASK:

- For each subchapter 5.1 to 5.3:
 - What questions are being addressed here?
 - What should you pay attention to / what should you place particular emphasis on when documenting?

EXAMPLE ANSWER

Section	Questions regarding the fulfillment of the section	How is it documented?
5.1 Leadership and Commitment	How does top management ensure that information security is embedded in the organization?	Management statement on information security : Documents management's support and commitment to ensuring the implementation and promotion of the ISMS. This statement is filed in the ISMS manual or as a separate document.
	What resources and support are provided to successfully operate the ISMS?	
	How is management actively involved in the implementation and continuous improvement of the ISMS?	
5.2 Information Security Policy	What are the organization's overarching security goals?	Information Security Policy : A strategic document outlining the organization's commitments, objectives, and guidelines regarding information security. The policy is communicated to all employees and documented in the ISMS manual.
	How can it be ensured that all employees understand the goals and requirements of information security?	
	How is the information security policy communicated and regularly reviewed within the organization?	
5.3 Roles, responsibilities and authorities in the organization	What roles are necessary to effectively operate and monitor the ISMS?	Role and responsibility matrix : An overview that defines roles, responsibilities, and authorities. Alternatively, this can be included in job descriptions to clarify tasks and responsibilities related to the ISMS. This can be part of the ISMS manual or maintained as a separate document.
	What specific responsibilities and powers do each role require?	
	How are roles and responsibilities communicated and documented to ensure clarity for all involved?	

TASKS

Task 1: Management commitment to information security

Description : List three concrete steps that management could take to demonstrate its commitment to information security. Briefly explain why each step is important.

Question : What specific controls can management take to demonstrate its commitment to information security?

Task 2: Development of an information security policy

Description : Design a short sample information security policy for the sample organization that includes a central objective as well as a commitment to the continuous improvement of security controls.

Question : What might an information security policy look like that clearly defines the organization's objectives?

Task 3: Define roles and responsibilities

Description : Describe two key roles within the ISMS (e.g., ISMS manager and IT security officer) and their most important tasks in information security.

Question : What roles and responsibilities are necessary to operate an effective ISMS?

Task 4: Communication of Information Security Policy

Description : Name two ways in which the information security policy can be effectively communicated to all employees within the organization. Explain why the chosen communication methods are effective.

Question : How can it be ensured that all employees know and understand the information security policy?

EXAMPLE ANSWER

Task	Example answer
1. Management commitment to information security	Management steps :
	1. Provision of sufficient resources for the ISMS
	<i>Rationale</i> : Shows that management takes information security seriously and invests in it.
	2. Participation in regular ISMS audits
	<i>Rationale</i> : Regular reviews ensure that security objectives are met and problems are identified early.
	3. Communicating the importance of information security to all employees
	<i>Rationale</i> : Conveys that information security is a priority and must be practiced by everyone.

EXAMPLE ANSWER

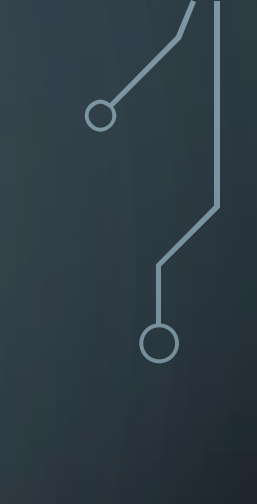
Task	Example answer
2. Development of an information security policy	Example information security policy : "The example organization is committed to maintaining the confidentiality, integrity, and availability of all information. Our goal is to meet all relevant legal and business requirements and to continuously improve our security controls to minimize risks and ensure the safety of all stakeholders."
3. Define roles and responsibilities	Roles and responsibilities : 1. ISMS Manager : Responsible for the development, implementation and maintenance of the ISMS; coordinates all ISMS activities and ensures that the ISMS meets the requirements. 2. IT Security Officer : Conducts risk analyses, develops technical security controls and ensures compliance with IT security guidelines.

EXAMPLE ANSWER

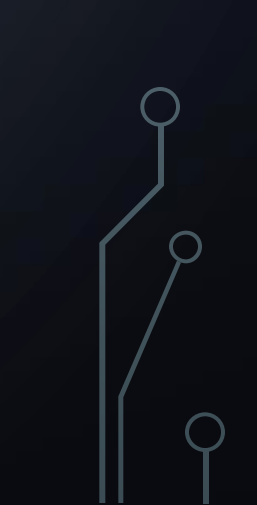
Task	Example answer
4. Communication of Information Security Policy	Communication channels :
	1. Training and workshops : Regular training ensures that employees understand the information security policy and practice its implementation.
	2. Publication on the intranet : Easily accessible publication allows employees to view the guidelines at any time and find information as needed.
	<i>Rationale</i> : Training promotes understanding and intranet access enables continuous availability of information.

CHAPTER 6: PLANNING

subsection	Who has to do it?	When will it be done?	Does it need to be documented?
6.1 controls for dealing with risks and opportunities	Top management and ISMS managers	At the beginning of the ISMS process and in the event of significant changes in the environment	Yes, the handling of risks and opportunities must be documented.
6.1.1 General	ISMS Manager	At the beginning of the ISMS implementation and regularly	Yes, the planning and implementation of controls must be documented.
6.1.2 Risk assessment in connection with information security	ISMS team, often including subject matter experts	Regularly and whenever changes occur that could affect the risk	Yes, the risk assessment process and the results must be documented.
6.1.3 Risk treatment in connection with information security	ISMS managers and security officers	After the risk assessment and if necessary (e.g., in the case of newly identified risks)	Yes, the risk treatment plan and the Statement of Applicability (SoA) must be documented.
6.2 Information security objectives and planning to achieve them	Top management and ISMS team	At the beginning of the ISMS process and annually or in the event of significant changes	Yes, the information security objectives and the plan to achieve these objectives must be documented.



TASK: VALUES & INFORMATION

- Create a list of potential information and associated assets that may need protection for TechSoft (example company).
 - Divide the assets into meaningful categories.
 - Explain if necessary.
- 
- 

EXAMPLE ANSWER

category	Asset	Description
information	Customer databases	Contains confidential information about customer projects and requirements.
	Source code repositories	Storage of the developed source code for different projects.
	Internal documentation	Guidelines, procedures and internal manuals.
	Contract documents	Agreements with customers, suppliers and partners.
	Employee data	Personal and professional information of employees.
software	Development tools	Licenses for IDEs, debuggers and other development software.
	Project management software	Tools for managing projects, tasks, and resources.
	Communication platforms	Software for internal and external communication (e.g., email, instant messaging).
Hardware	Server and network infrastructure	Physical servers, routers, switches and other network devices.
	Employee devices	Laptops, desktops and mobile devices used by employees.
	Backup systems	Devices and media for data backup.

EXAMPLE ANSWER

category	Asset	Description
Intangible assets	Company logo and brand name	They represent the market value and reputation of the company.
	Patents and copyrights	Intellectual property rights for developed software and technologies.
	Trade secrets	Proprietary methods, algorithms, and processes.
Human resources	Expertise of the staff	The workforce's expertise and experience in various technologies and industries.
	Leadership skills	Strategic and operational management skills.
Physical resources	Office building and facilities	Premises in Frankfurt am Main, including offices and meeting rooms.
	Safety equipment	Access control systems, surveillance cameras and alarm systems.
Financial resources	Bank accounts and financial reserves	Liquidity to ensure business operations.
	Investments	Investments in other companies or funds.

EXAMPLE ANSWER

category	Asset	Description
reputation	Customer reviews and testimonials	Customer feedback and recommendations that influence TechSoft's reputation.
	Media presence	Mentions in journals, blogs and other media.
Contracts and agreements	Service Level Agreements (SLAs)	Agreements regarding the services to be provided and their quality.
	Partnerships	Agreements with other companies for joint business development.
Compliance and certifications	ISO 27001 certification	Proof of compliance with international standards for information security management.
	Data protection agreements	Documents confirming compliance with data protection laws.

REQUIREMENTS

Requirement	Description
Determining the scope of the ISMS	The scope of the ISMS must be clearly defined to ensure that all relevant systems, processes and locations are covered.
Context analysis of the organization	The organization must understand the internal and external influences (e.g., legal requirements, market conditions, corporate goals) that can affect information security.
Identifying stakeholders	Relevant stakeholders and their expectations regarding information security must be identified in order to incorporate their requirements into the risk assessment.
Defined risk assessment methodology	A formalized methodology for risk assessment must be established. This should include criteria for risk classification, probability assessment, and impact.
Acceptance criteria for risks	The organization must establish acceptance criteria that specify which risks are acceptable and which require treatment. These criteria are often based on the company's risk appetite.
Asset assessment	A list of all assets to be protected must be created. This includes data, systems, facilities, and personnel resources that fall within the scope of the ISMS.
Identification of threats and vulnerabilities	Potential threats and vulnerabilities to the identified assets must be identified to form the basis for risk assessment.
Risk awareness in the company	Employees must have a basic understanding of risks and their significance for information security. This includes training and awareness-raising controls.

The background is a dark blue gradient with faint, large concentric circles. In the corners, there are white line art elements resembling circuit boards or neural networks, with lines and small circles connecting them.

RISK TREATMENT

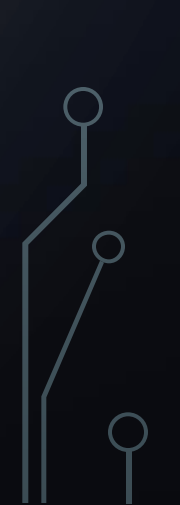


TASK:

- Outline the options a company has for managing risk.

Example risk: A thief/saboteur/industrial spy could enter the factory through the gate.

The question does not focus on the specific controls to manage this risk, but rather on how risk can be addressed.



RISK TREATMENT OPTIONS

Risk treatment option	Explanation	Example	Risk factory gate
Avoid the risk	controls are taken to eliminate the risk completely, often by avoiding the risky activity.	A company decides not to implement a certain unsafe technology in order to avoid the risk.	The factory gate will be closed forever.
Reduce risk	controls are implemented to reduce the probability and/or the impact of a risk.	Use of firewalls, encryption and access controls to minimize security threats.	The factory gate is secured by turnstiles and company ID card readers.
Share/transfer risk	The risk is partially or completely transferred to third parties, for example through insurance or outsourcing.	Taking out cyber insurance to cover financial losses due to security incidents.	A security company is hired.
Accept the risk	The risk is consciously accepted if the costs or effort required for controls are disproportionately high.	A small company accepts the low risk of a temporary system outage due to budget restrictions.	The company is confident that other controls will definitely be effective and lives with what it considers a low risk without taking any action.

RISK ASSESSMENT: 5X5 MATRIX

	Very minimal impact	Minimal impact	Medium impact	High impact	Very high impact
Very high probability	Medium risk	High risk	Critical risk	Critical risk	Critical risk
High probability	Low risk	Medium risk	High risk	Critical risk	Critical risk
Medium probability	Low risk	Medium risk	High risk	High risk	Critical risk
Low probability	Low risk	Low risk	Medium risk	High risk	High risk
Very low probability	Low risk	Low risk	Low risk	Medium risk	High risk

Risk level	Plot
Low risk	No action required. Regular reassessment is necessary.
Medium risk	Observe & Regularly Check
High risk	Treat & actively monitor
Critical risk	Urgent treatment and monitoring required.

DOCUMENTATION PROPOSAL

Asset No.	Asset Name	Vulnerability	Threat	Likelihood	Impact	Risk Rating	Risk Owner	Existing Controls
				High	High			
				High				
				Medium				
				Low				

NOTE: APPENDIX A

- 6.1.3 c and d require consideration of the controls listed in Annex A.
- For each measure, its use or exclusion must be documented.
- The list may (and should) be supplemented with your own controls.
- Including the 27002 is helpful.

RECOMMENDED: CONSULT THE BSI BASIC PROTECTION OFFICE

- The IT Baseline Protection (BSI) lists 47 threats.
- These will be explained in detail
- This list can be helpful in risk analysis.

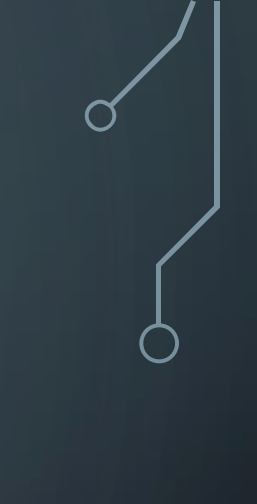
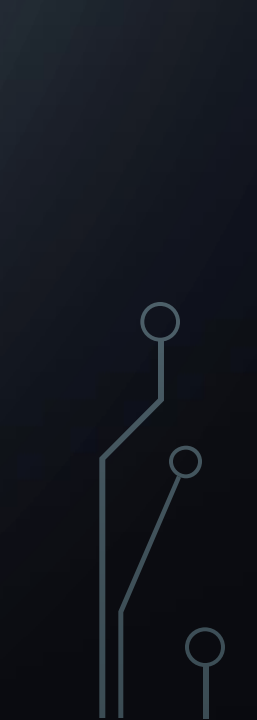
https://www.bsi.bund.de/DE/Themen/Unternehmen-und-Organisationen/Standards-und-Zertifizierung/IT-Grundschutz/IT-Grundschutz-Kompendium/Elementare-Gefahren/elementare-gefahren_node.html

6.2 INFORMATION SECURITY OBJECTIVES

aspect	Information security objectives (Chapter 6.2)	Information Security Policy (Chapter 5.2)
Purpose	Information security objectives define concrete, measurable results that the ISMS should achieve. They are targeted and specific.	The information security policy represents the company's fundamental intention and orientation in the area of information security. It defines the strategic direction.
character	Operational : The objectives are specific and often short- to medium-term, with clear key performance indicators (KPIs).	Strategically : The policy is overarching and long-term oriented, serving as a guideline for the entire company.
Examples	"Reducing the number of successful phishing attacks by 50% within one year."	"The organization is committed to protecting confidential information."
	"Ensuring that 100% of employees receive information security training annually."	"The company ensures that all legal and regulatory requirements are met."
Measurability	Yes : The goals must be measurable in order to verify their achievement (SMART criteria: specific, measurable, achievable, relevant, time-bound).	No : Politics does not have to be measurable, but rather provides a framework and describes principles.
responsibility	They are often set and monitored by the ISMS team or department heads, with management support.	The policy is set and communicated by top management to demonstrate the company's commitment.
examination	Regularly monitored and updated to ensure they are reached and adapted to changes.	It is regularly reviewed by management, but usually remains constant and fundamental over a longer period of time.



TASK

- Define two security policies for TechSoft.
 - Suggest corresponding objectives, which measurements can be used for these objectives, and how the objectives can be verified.
- 
- 
- 

EXAMPLE ANSWER

Information security policy	Information security objectives	measurement	examination
1. Protection of confidential information	Reduction of the number of data protection incidents by 30% within one year.	Measurement : Number of documented data protection incidents.	Verification : Regular audits to record data protection incidents and to confirm encryption controls.
"We are committed to ensuring the confidentiality of all sensitive information."	100% encryption of all sensitive data on servers and end devices.	Measurement : Verification of encryption settings on end devices and servers.	
2. Employee training and awareness training	95% of employees are required to complete information security training annually.	Measurement : Participation rate in training courses (training database).	Review : Evaluation of training records and analysis of phishing simulations to identify areas for improvement.
"All employees must be aware of their responsibility in the area of information security."	Conducting monthly phishing simulations with a success rate of less than 10%.	Measurement : Success rate of the phishing simulations (email click rate).	

EXAMPLE ANSWER

Information security policy	Information security objectives	measurement	examination
3. Compliance with legal and regulatory requirements	Complete 100% of the legally required compliance checks within the deadlines.	Measurement : Tracking of completed compliance audits.	Verification : Regular review of compliance checklists and monitoring of audit reports for potential violations.
"We ensure that all legal and regulatory requirements for information security are met."	0% violations in internal and external audits regarding legal requirements.	Measurement : Number of violations identified in audit reports.	
4. Ensuring system availability	Ensure that critical systems are 99.9% available.	Measurement : Availability statistics of the systems (monitoring tool).	Verification : Monthly reporting of system availability and annual test review of the disaster recovery plan.
"We are implementing controls to guarantee the high availability of our critical systems."	Implementation and testing of an emergency recovery plan within the next year.	Measurement : Documented test results of the emergency recovery plan.	
5. Controlling access to confidential data	Review 100% of employee access to confidential data annually.	Measurement : Completion rate of access checks.	Verification : Regular review of access rights and quarterly review of the MFA implementation status.
"Access to confidential data is strictly controlled and regularly reviewed."	Implementation of multi-factor authentication (MFA) for all sensitive systems by the end of the year.	Measurement : Implementation status of MFA on the relevant systems.	

WHAT IS SOA?

Contents	Description
List of applicable security controls	The SoA document contains a complete list of all 93 security controls from Annex A of ISO 27001:2022 that the company is considering.
Implementation status	For each control, it is documented whether it is implemented , partially implemented , planned , or not implemented . This provides an overview of the current implementation status of the security controls.
Reason for selection or exclusion	For each control, the reasons why it was implemented or why it is not applicable are stated. These justifications should be based on the results of the risk assessment and the organization's requirements.
Reference to risks and controls	Optionally, the Statement of Action (SoA) can also include references to risk assessments or specific controls related to the respective controls. This clarifies which risk is addressed by which control.
Versioning and approval	The Statement of Action (SoA) should be updated regularly. Versioning and management approval are required to ensure the document is up-to-date and has the approval of senior management.

WHAT IS SOA?

- The SoA is the link between risk analysis and security controls.
- It documents:
 - what we do
 - why we do it
 - where we stand.

SOA – SIMPLIFIED EXAMPLE

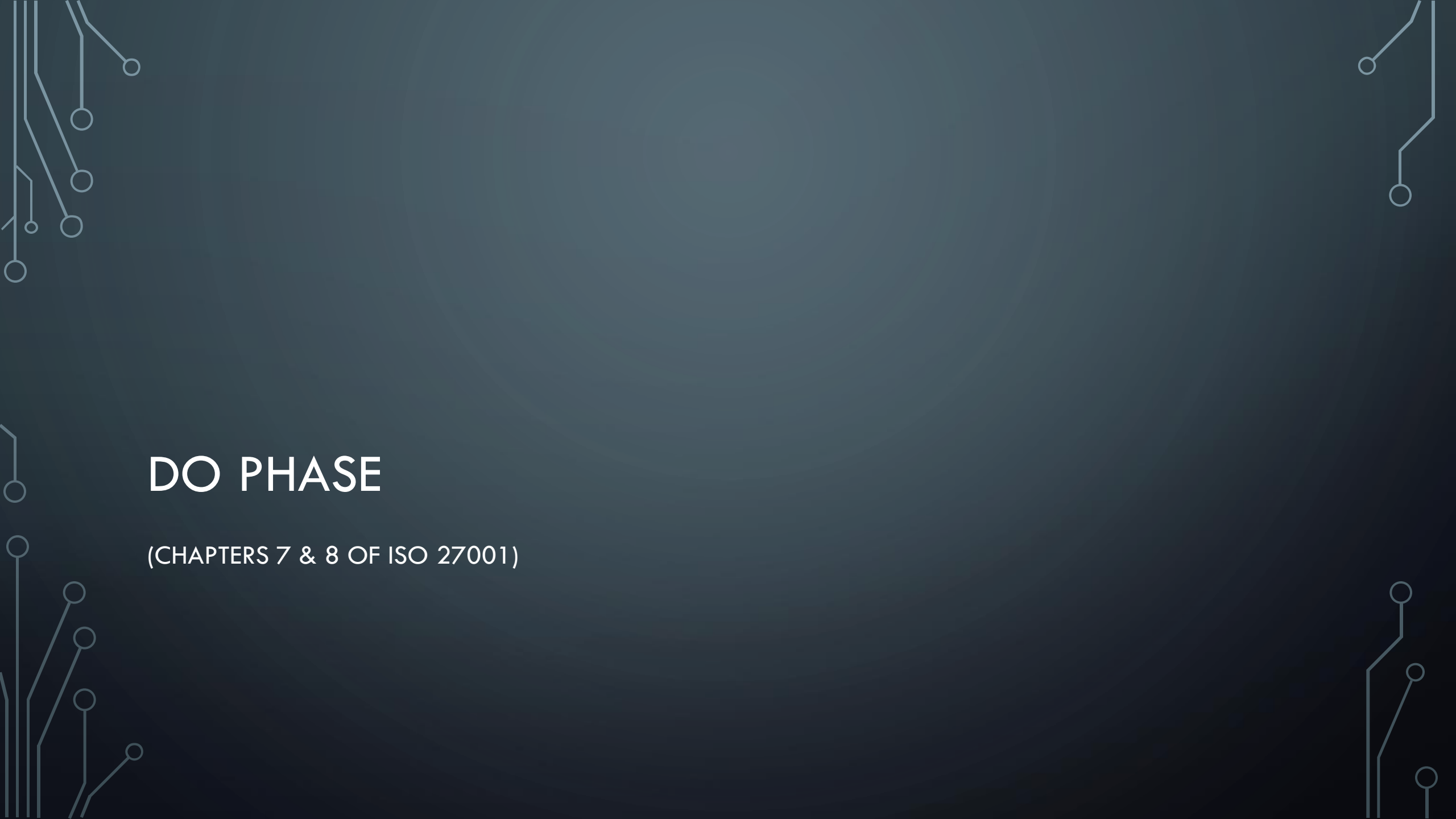
Control	status	Reason	reference
A.5.9 – Access Control	Implemented	Role-based access restrictions are necessary	Access Control Policy v2.1
A.8.13 – Backup	Partially implemented	Backups available, no recovery tests.	Backup Policy v1.3
A.6.3 – Awareness	Planned	New e-learning system under development	Awareness Plan 2025
A.5.7 – Supplier Management	Not applicable	No external service providers with access to customer data	–

WHAT WAS ACHIEVED IN THE PLAN PHASE?

Chapter	Theme	Results achieved	Required documents
Chapter 4	context of the organization	Understanding the internal and external issues that affect the organization	Document on the context analysis of the organization
		Identification of relevant stakeholders and their requirements	Stakeholder analysis
		Determining the scope of the ISMS	Documented scope of the ISMS
Chapter 5	Leadership and commitment	Establishment of the organization's ISMS policy	ISMS policy
		Roles, responsibilities and authorities defined in the ISMS	Role and responsibility matrix
		Ensuring management commitment	Record of management commitment (e.g., meeting notes)

WHAT WAS ACHIEVED IN THE PLAN PHASE?

Chapter	Theme	Results achieved	Required documents
Chapter 6	planning	Risk assessment and risk treatment processes defined	Risk assessment and risk treatment documents
		Risk treatment plan created with identified risks and controls	Risk treatment plan
		Information security goals defined and established at various levels	Document on Information Security Goals
		Key performance indicators (KPIs) have been defined to measure the success of the ISMS.	Document on KPIs for the effectiveness of the ISMS
		Risk treatment controls aligned with the controls defined in Annex A	Statement of Applicability (SoA)

The background is a dark blue gradient with a large, faint, light blue circle in the center. In the four corners, there are white line art illustrations of circuit boards or wiring, with small circles representing components or connection points.

DO PHASE

(CHAPTERS 7 & 8 OF ISO 27001)

DO PHASE: CONTENTS

Chapter	Theme	Tasks in the Do phase	Expected documentation / results
Chapter 7	Support	Provision of the necessary resources for the ISMS	Documentation of resource planning
		Ensuring the competence of the employees involved in the ISMS	Training and qualification certificates
		Promote employee awareness of ISMS goals and importance	Records of awareness controls (e.g. training certificates)
		Ensure internal and external communication	Communication plan for ISMS
		Create, manage, and update documented information	Procedural documents, work instructions, guidelines
Chapter 8	Operation	Planning and control of operational controls for risk management	Documented operating plan
		Implementation of the defined risk management controls	Evidence of control implementation
		Administration and operation of the ISMS processes in accordance with the defined procedures	Process documentation and work instructions
		Implementation of incident management for information security incidents	Incident management protocols and report templates
		Monitoring and control of operational processes to identify and correct deviations.	Monitoring reports and deviation logs

TASK: EXPLAIN THE PROCEDURE.

Resource planning

Competence of
those involved

Raising awareness
among the
workforce (creating
consciousness)

Communication
(internal / external)

Management of
documented
information

EXAMPLE ANSWERS

Task	Proceed	Goal	Expected documentation
Resource planning	Determining the required resources (personnel, infrastructure, financial resources and time requirements)	Ensuring sufficient resources for the ISMS	Resource needs analysis, budget plan
	Coordination with management to approve resources	Approval and provision of necessary resources	Management protocols, approvals
	Documentation of allocated resources	Transparency regarding available and deployed resources	Resource plan
Competence of those involved	Identifying required competencies for the roles in the ISMS	Ensure that all roles have the necessary skills	Competency requirements
	Assessment of current employee skills	Matching existing skills with required skills	Competency matrix
	Organize targeted training or qualification controls to address skills gaps.	Improving qualifications for ISMS-specific requirements	Training plans, proof of completed qualifications
Raising awareness among the workforce	Conducting awareness training and information events	Promoting safety awareness among all employees	Training certificates, attendance records
	Distribution of ISMS guidelines and regular security updates	Increased attention to security controls	Guides, newsletters, awareness materials
	Use of intranet, memos, or posters to remind people of safety practices	Integrating security awareness into everyday life	Documentation of the actions carried out

EXAMPLE ANSWERS

Task	Proceed	Goal	Expected documentation
Communication (internal/external)	Development of a communication plan that takes into account internal and external stakeholders	Transparent and targeted communication	Communication plan
	Designating contact persons for internal and external inquiries	Clarity regarding responsibilities and communication channels	List of contact persons, contact information
	Regular communication to all stakeholders about ISMS goals, procedures and results	Promoting understanding and support for the ISMS	Communication reports, meeting minutes
Management of documented information	Creating and maintaining procedural documents, guidelines and instructions	Ensuring consistent and transparent documentation	Guidelines and procedures, work instructions
	Setting access rights and retention periods for documents	Protection and up-to-dateness of ISMS documentation	Access and retention guidelines
	Regular review and updating of the documented information	Current and accurate documentation	Document audit logs, update records

TASK

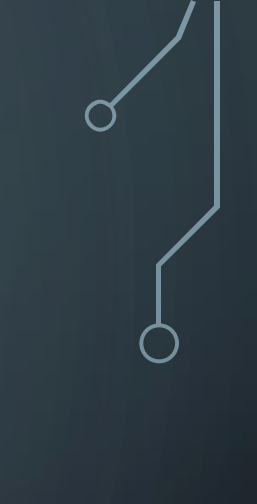
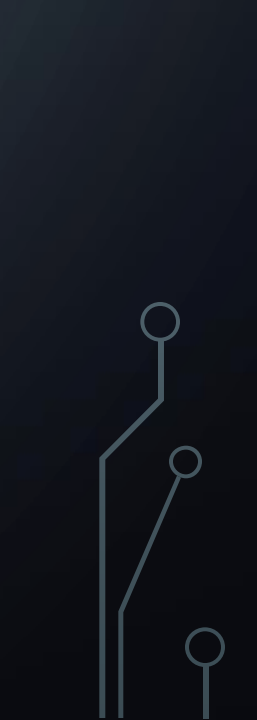
- Create a communication plan (example)
 - What information does the plan contain?
 - Create 2 sample entries from the plan

EXAMPLE ANSWER

Theme	Target audience	Contents	Responsible person	frequency	Communication channel	Goal
ISMS goals and policy	All employees	Explanation of the ISMS objectives and their significance	ISMS Officer	Quarterly or upon updates	Email, intranet, meetings	Creating an understanding of the relevance of the ISMS
Roles and responsibilities in the ISMS	ISMS team and management	Assignment and explanation of specific roles and responsibilities	ISMS Officer	One-time or in case of changes	Workshops, Meetings	Creating clarity about responsibilities in the ISMS
Awareness training	All employees	Training on safety awareness and practices	HR/Training Team	Yearly	Classroom training, e-learning	Promoting safety awareness
Risk assessment results	ISMS team, management	Overview of identified risks and planned controls	Risk manager	Semi-annually or as needed	Report, presentation	Creating transparency about risks and how they are handled
Status of ISMS controls	ISMS team, management	Progress and status reports on implemented controls	ISMS Officer	Monthly	Report, dashboard, meeting	Monitoring and control of the controls ensure
Information security incidents	ISMS team, affected departments	Information about incidents and corresponding countercontrols	Incident Manager	In case of incidents	Email, Meeting	Ensure a rapid response to security incidents
Audit results	ISMS team, management	Report on the results of internal and external audits	Auditor	After each audit	Report, presentation	Improvements and corrections enable
Changes in the ISMS	All employees	Updates regarding changes to ISMS policies or procedures	ISMS Officer	As needed	Email, intranet, meetings	Updating knowledge of ISMS procedures



TASK

- What does ISO 27001:2022 mean by the term document control?
 - Why is this term considered important?
- 
- 
- 

EXAMPLE ANSWER

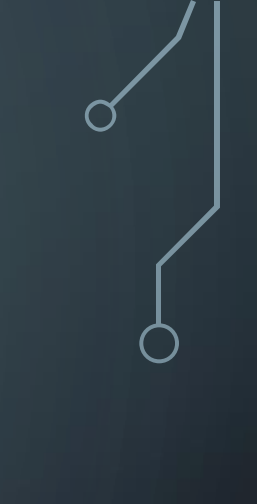
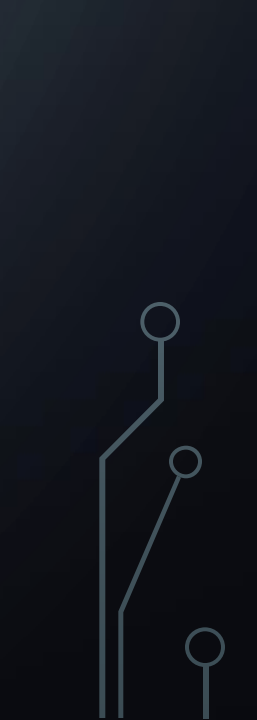
- ISO 27001:2022 defines document control as the systematic management and control of documented information to ensure that it is up-to-date, accessible, secure and accurate.
- This ensures the integrity and reliability of documented information within the ISMS.

EXAMPLE ANSWER

Aspect of document control	Description	Purpose
Creation and approval	Documents are created and checked for accuracy and completeness before release.	Ensuring the quality and relevance of the documents
Versioning and updates	Changes to documents are versioned and updated to maintain a consistent and traceable history.	Ensuring up-to-dateness and traceability
Release and distribution	Defining who is allowed to release documents and how they are distributed within the company.	Ensuring that only authorized versions are used
Access rights and confidentiality	Access rights to documented information are determined according to security requirements.	Protection against unauthorized access and ensuring confidentiality
Retention and deletion periods	Definition of retention periods and procedures for the secure deletion of outdated documents.	Compliance with legal and regulatory requirements
Protection and archiving	controls to secure and archive documents to ensure their availability even in emergencies.	Ensuring long-term availability
Testing and inspection	Regular review of the documentation for accuracy and timeliness, e.g. through internal audits.	Ensuring compliance with ISMS requirements
Availability and accessibility	Ensuring that documented information is easily accessible to authorized persons.	Facilitating the use and implementation of the ISMS



TASK

- Differentiate between the terms information security incident and information security problem. Explain the relationship between the two terms.
- 
- 
- 

EXAMPLE ANSWER

Expression	definition	relationship to each other
Information security incident	An event that could compromise information security, but does not necessarily result in damage. This includes unusual activities that potentially pose a threat.	An incident can be the first indication of a problem. It requires investigation to determine whether it has escalated into an information security incident.
Information security incident (problem)	A confirmed incident where a threat actually resulted in an impairment of information security, e.g., data loss or unauthorized access.	A problem often arises from an incident that has led to a specific impairment. Incidents usually require further controls for recovery and prevention.



TASK

- The incident process (information security event) is a key element in managing information security within a company.

What might such a process look like?



EXAMPLE ANSWER

Step	Description	Responsible person/department	Expected result
1. Incident detection	Identification of a potential security incident by employees or technical systems.	All employees, IT monitoring systems	Initial detection and reporting of a potential incident
2. Incident Reporting	Employees or systems report the incident via a defined reporting system (e.g., ticket system, email).	Affected employee, IT service desk	Official registration of the incident
3. Recording and documentation	Detailed documentation of the incident, including description, affected systems and potential risks.	IT Security Officer	Complete and accurate documentation
4. Evaluation and Prioritization	Assessment of the incident regarding urgency and potential impact on the company.	IT Security Officer, IT Team	Prioritized list of incidents
5. Initiate initial controls	Implementing immediate controls to minimize damage or contain the incident.	IT Security Officer, Incident Team	Containment of the incident
6. Analysis and Investigation	Analysis of the causes and effects of the incident, as well as identification of vulnerabilities.	Incident response team, IT forensics	Findings on cause and effect

EXAMPLE ANSWER

Step	Description	Responsible person/department	Expected result
7. Escalation (if necessary)	In the event of critical incidents, management is informed and external experts are consulted if necessary.	IT Security Officer, Management	Support through additional resources
8. Solution and Restoration	Resolution of the incident and restoration of normal operating conditions.	IT team, affected departments	Restoration of normal operation
9. Documentation of the solution	Documentation of the controls taken to resolve the incident and their success.	IT Security Officer	Complete documentation of the solution
10. Follow-up and prevention	Analysis of the incident to derive preventive controls and avoid future incidents.	IT Security Officer, Management	Improved security controls and lessons learned
11. Conclusion and Report	Incident closure with the preparation of a final report for management and documentation.	IT Security Officer	Final report with lessons learned and recommendations

DO PHASE: GOALS

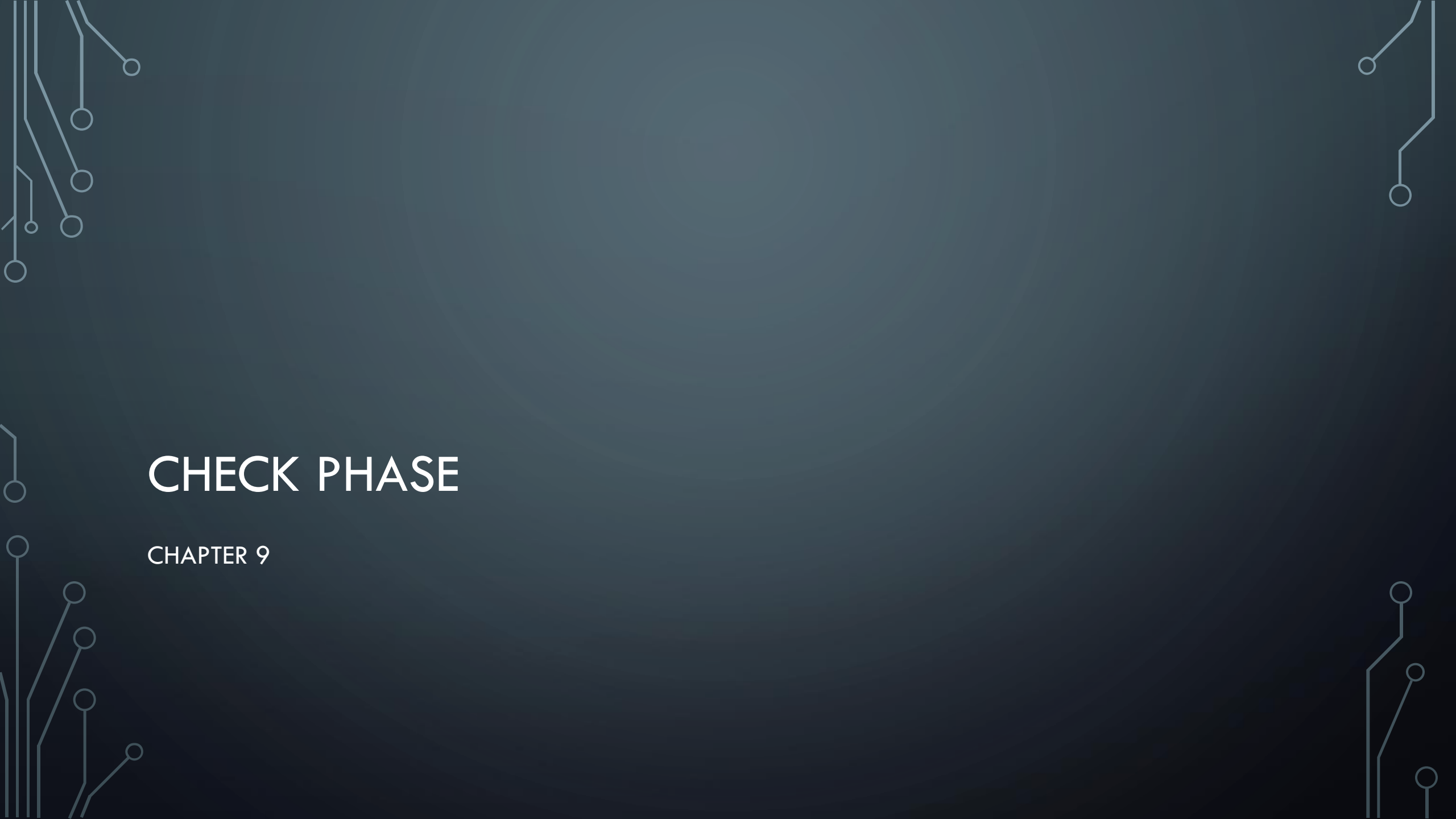
- In the Do phase (chapters 7 and 8 of ISO 27001:2022), the concepts and strategies developed in the Plan phase are implemented. This phase ensures that the necessary resources are provided, the relevant processes are implemented, and the risk treatment controls are carried out.
- It establishes the operational framework for the ISMS, ensures that all employees are competent and aware, and makes sure that all security controls are consistently implemented and continuously monitored.

DO PHASE: GOALS

Chapter	Theme	Results achieved
Chapter 7	Support	Provision of all necessary resources for the implementation of the ISMS.
		Ensuring the competence and training of the employees involved with regard to information security.
		Promoting safety awareness among all employees through targeted awareness controls.
		Implementation of a communication plan for internal and external information security communication.
		Effective management and control of documented information to ensure its availability and protection.
Chapter 8	Operation	Operational implementation of the planned controls for risk management and information security.
		Monitoring and control of processes and controls for risk treatment in accordance with the defined procedures.
		Management of information security incidents through defined incident management processes.
		Conducting regular reviews and checks to ensure that all ISMS controls are effective.
		Documentation and evidence of the implemented security controls and steps taken to address risks.

DO PHASE: GOALS

- ISMS is operationally functional.
- Employees are empowered and sensitized
- Security controls are carried out in a controlled manner in everyday life.
- Incidents are detected, treated, and analyzed.

The background is a dark blue gradient with a large, faint, light blue circle in the center. In the four corners, there are white line art illustrations of circuit traces and nodes. The top-left and bottom-left corners have more complex, branching circuit patterns, while the top-right and bottom-right corners have simpler, more linear patterns.

CHECK PHASE

CHAPTER 9

CHECK-IN PHASE: CONTENT

- In the **check phase** (Chapter 9 of ISO 27001:2022), the effectiveness of the ISMS is monitored, measured, analyzed and evaluated.

CHECK PHASE: INTERNAL AUDITS

aspect	Description	Goal	Expected results/documentation
Definition of measurement methods	Organizations must determine which methods will be used to monitor and measure ISMS performance.	Ensure that the measurement methods are reliable and relevant.	Description of measurement methods
			Definition of KPIs
Measuring effectiveness	Regular measurement of the effectiveness of ISMS processes and controls, based on defined KPIs.	Identifying strengths, weaknesses, and areas for improvement.	Monitoring reports
			KPI data
Analysis and evaluation	Analysis and evaluation of the collected data to identify trends, deviations, and potential for improvement. Responsible parties must be appointed.	Supporting decisions to improve the ISMS.	Analysis reports
			Recommendations for action
Frequency of monitoring	Determination of how often monitoring and measurement are carried out and by whom.	Regularity and continuity in the evaluation of ISMS performance.	Monitoring plan
reporting	The results of monitoring and measurement must be documented and communicated to relevant stakeholders.	Promoting transparency and supporting decision-making.	Reports and presentations for management and ISMS teams

CHECK PHASE: CONTENT

Task	Description	Expected results/documentation
Monitoring and measurement	Monitoring and measurement of ISMS processes and controls according to the defined KPIs and objectives.	Measurement data and reports on the KPIs
		Logs of monitoring activities
Analysis and evaluation	Analysis of the collected data to evaluate the effectiveness of the controls and results of previous audits and to identify potential areas for improvement.	Review reports
		Suggestions for improvements
Conduct internal audits	Regular internal audits to verify the ISMS's compliance with ISO 27001 and the effectiveness of the controls.	Audit reports
		Findings and recommendations
Management review	Assessment by top management to ensure the suitability, adequacy and effectiveness of the ISMS.	Management review minutes
		Decisions and action plans

CHECK PHASE: CONTENT

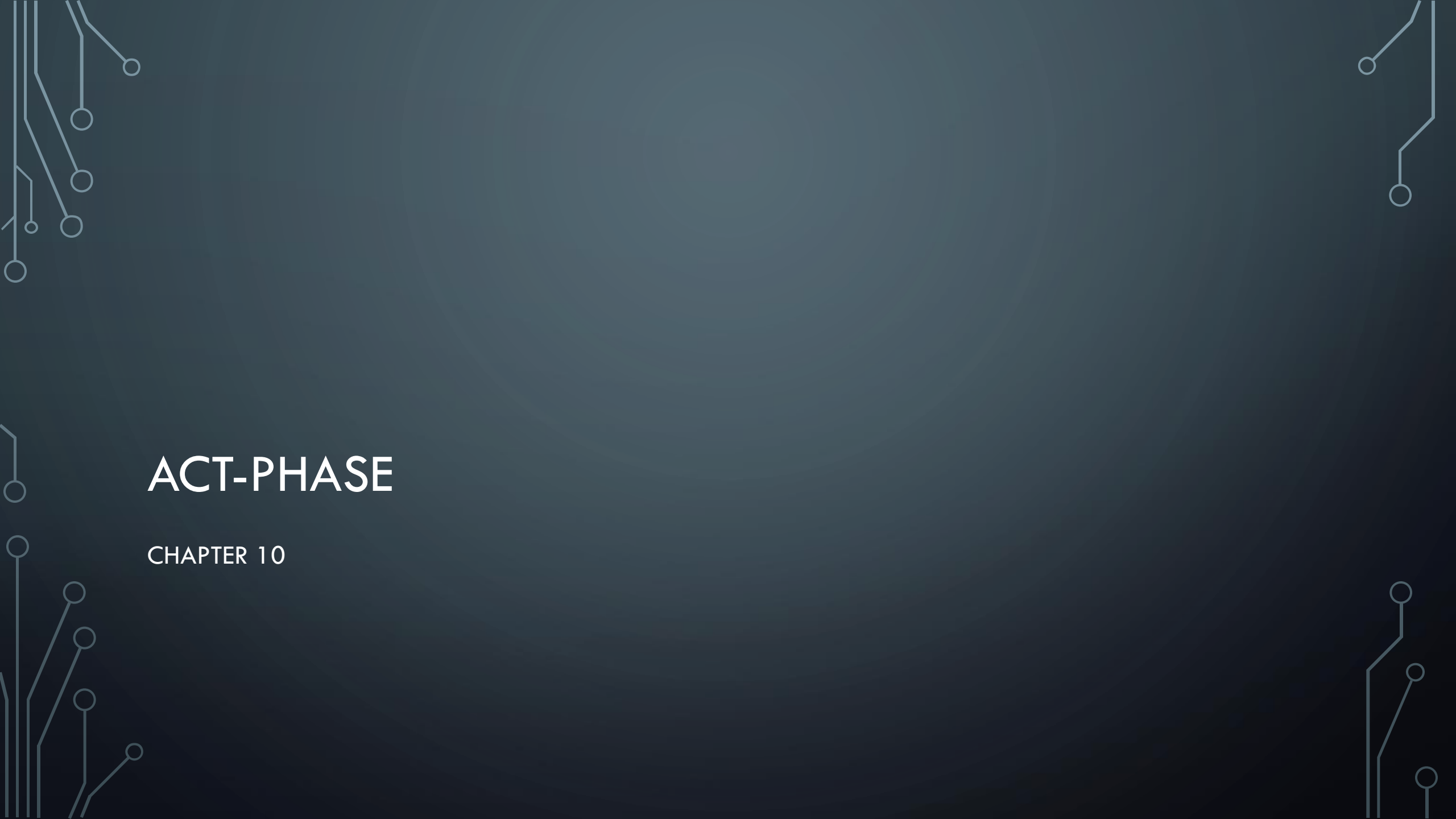
Task	Description	Expected results/documentation
Review of security incidents	Analysis of reported security incidents to identify trends and prevent recurrences.	Reports on incidents and deviations
		Documented Lessons
Reviewing the fulfillment of information security objectives	Ensure that the goals defined in the planning phase are achieved.	Report on goal achievement
Verification of compliance with requirements	Check whether legal, regulatory and contractual requirements are being met.	Compliance reports
		Deviation logs

EXERCISE

- Where is the requirement – if any – in Chapter 9 that the entire ISMS must be examined through the regularly conducted audits?

EXAMPLE ANSWER

Chapter	Contents
Chapter 9.2 (Internal Audit)	The internal audit must verify whether the ISMS meets the requirements of ISO 27001, including the company's requirements and the ISMS scope.
	It must be carried out regularly, with the frequency and depth determined based on risks and changes in the ISMS.
Chapter 9.3 (Management Evaluation)	Top management must ensure that the ISMS is regularly reviewed for suitability, adequacy, and effectiveness.
	The results of the internal audits are incorporated into the management review.

The background is a dark blue gradient with a large, faint, light blue circle in the center. In the four corners, there are white line-art illustrations of circuit boards or neural networks, featuring lines and small circles.

ACT-PHASE

CHAPTER 10

ACT-PHASE: CONTENT

Task	Description	Expected results/documentation
Taking corrective action	Deviations identified through audits, monitoring, or incidents must be corrected.	Report on corrective actions
		Evidence of implementation
Review of the effectiveness of controls	Ensure that corrective actions are effective and solve the problem in the long term.	Evaluation of the controls
		Success Stories
Analysis of trends and causes	Analyzing trends from monitoring data, security incidents, or audit results to identify patterns.	Trend analyses
		Root cause analyses
Identification of potential improvements	Based on the reviews and analyses, define new controls to optimize the ISMS.	Document with suggestions for improvement

ACT-PHASE: CONTENT

Task	Description	Expected results/documentation
Implementation of improvement controls	Introduction of processes, technologies or training that contribute to increasing ISMS effectiveness.	Project plans for improvements
		Evidence of implementation
Documentation of the adjustments	Ensure that changes to the ISMS are documented and communicated to all relevant stakeholders.	Updated ISMS documentation
		Change reports

AUTOMATIC ADJUSTMENT

ACT

PLAN

DO

Learning from the
past

Preparing for the
FUTURE

Acting in the
PRESENT